

ISO 27001 Framework Overview

Introduction

ISO 27001 is popular due to its comprehensive approach to information security management. It provides a systematic framework for managing sensitive company information, ensuring its confidentiality, integrity, and availability. Here are some key reasons for its popularity and benefits over other frameworks.

Popularity and Benefits of ISO 27001

Aspect	Explanation
Global Recognition	ISO 27001 is internationally recognized, making it applicable to businesses across different countries and industries.
Comprehensive	Covers all aspects of information security, not just IT security, but also physical security, human resources, etc.
Risk-Based Approach	Emphasizes identifying risks and applying controls based on the organization's risk appetite and environment.
Certifiable	Organizations can achieve ISO 27001 certification to demonstrate their commitment to information security.
Continuous Improvement	Aligns with ISO's Plan-Do-Check-Act (PDCA) model, encouraging continuous improvement.
Third-Party Assurance	Provides external validation and builds trust with clients, partners, and regulatory bodies.
Legal and Regulatory Compliance	Helps meet legal and regulatory obligations, such as GDPR, HIPAA, and other industry-specific regulations.
	I

Alignment with Other Frameworks	SO 27001 can integrate with other standards like ISO 9001 (quality management) and ISO 22301 (business continuity).
---------------------------------	---

ISO 27001 Controls and Requirements

ISO 27001 has Annex A, which contains 14 control domains and 114 controls in total. These controls aim to mitigate risks identified during the risk assessment phase. Below is a table outlining the control categories, control objectives, examples of tools, and their mandatory/non-mandatory status.

Control Category	Control Objectives	Examples of Tools	Mandatory Documents	Non-Mandatory Documents	Use Cases
A.5 Information Security Policies	Management direction for ISMS.	Policy management tools (e.g., DocuSign)	Information security policy	—	General guidance for security management within an organization.
A.6 Organization of Information Security	Roles, responsibilities, and authorities.	Identity and access management (IAM) tools (e.g., Okta)	Responsibilities for security	—	Ensures security roles are clearly defined in organizational structure.
A.7 Human Resource Security	Ensures that employees and contractors understand their roles in security.	Background check platforms, HR software	Security clauses in contracts	Training records, background checks	Mitigating insider threats by ensuring proper onboarding and offboarding practices.

A.8 Asset Management	Identifying and classifying information assets.	Asset management tools (e.g., Lansweeper, SolarWinds)	Asset inventory	Classification schema	Helps in tracking physical and digital assets to ensure protection.
A.9 Access Control	Managing access to systems and data.	IAM tools (e.g., Okta, AWS IAM)	Access control policy	User access reviews, privileged access logs	Ensuring only authorized personnel have access to critical systems.
A.10 Cryptography	Ensuring proper encryption practices.	Encryption tools (e.g., PGP, AWS KMS)	Encryption policy	Encryption key management process	Protecting sensitive data by encrypting at rest and in transit.
A.11 Physical and Environmental Security	Prevent unauthorized physical access.	Physical access control systems, CCTV	Physical security policy	Visitor logs, site access logs	Protects the physical premises and IT infrastructure.
A.12 Operations Security	Ensure secure operation of IT systems.	SIEM tools (e.g., Splunk, ELK Stack)	Operational procedures	Backup logs, maintenance logs	Ensures systems are operated in a secure and reliable manner.
A.13 Communications Security	Ensures the secure transfer of information.	VPNs, TLS, SSL certificates, firewalls	Network security policy	Communication logs, encryption certificates	Protecting sensitive data while it is transferred over

					networks.
A.14 System Acquisition, Development, and Maintenance	Ensures security in system development lifecycle.	DevSecOps tools (e.g., Jenkins, GitHub)	Secure development policy	Secure coding standards	Ensures that security controls are integrated throughout the SDLC.
A.15 Supplier Relationships	Protects information shared with third parties.	Vendor risk management tools (e.g., Archer)	Supplier security policy	Contracts with security clauses	Ensures third-party suppliers meet security expectations .
A.16 Information Security Incident Management	Detecting and responding to incidents.	Incident response platforms (e.g., Splunk SOAR)	Incident response policy	Incident response logs	Guides organizations on how to handle security breaches.
A.17 Information Security Aspects of Business Continuity	Ensures ISMS continuity during disruptions.	Business continuity planning tools (e.g., DRI)	Business continuity policy	Disaster recovery plans, BCP tests	Keeps information security operations running during major disruptions.
A.18 Compliance	Meeting legal, regulatory, and contractual requirements .	Compliance tools (e.g., OneTrust, LogicGate)	Compliance policy	Internal audit reports, legal compliance registers	Ensures the organization complies with applicable laws and contractual obligations.

Mandatory and Non-Mandatory Documents

Category	Mandatory Documents	Non-Mandatory Documents
Information Security Policy	Information security policy, risk assessment methodology, risk treatment plan	Risk acceptance criteria, roles and responsibilities documents
Risk Management	Risk assessment and treatment methodology, risk treatment plan, Statement of Applicability (SoA)	Risk assessment reports, risk acceptance criteria
Asset Management	Asset inventory	Data classification policies, asset handling procedures
Incident Management	Incident response procedure, Incident logs	Post-incident review documents
Access Control	Access control policy	User access review logs, privileged access reports
Supplier Management	Supplier security policy	Contracts with security clauses, vendor assessment reports

Use Cases for ISO 27001

1. Multinational Corporations: Ensures consistent information security policies across different countries while complying with international regulations.
2. Healthcare Organizations: Helps meet regulatory requirements like HIPAA, ensuring the confidentiality and integrity of sensitive health information.
3. Financial Institutions: Protects sensitive financial data and ensures compliance with standards like PCI-DSS.
4. Small and Medium Businesses: Helps establish a formalized and scalable approach to information security as the business grows.
5. Technology Companies: Protects intellectual property and customer data, improving trust with partners and clients.